

Sample Security Audit Report

Startup Security Baseline Audit Framework - Controlled DVWA Laboratory Assessment

Assessment date: 18 September 2026 | Assessor: Spandana | Report type: Sample / portfolio deliverable

1. Executive Summary

What was audited. A Damn Vulnerable Web Application (DVWA) instance running in Docker on Ubuntu 24.04 (WSL2), reachable only on the local machine at 127.0.0.1:4280.

Why. To demonstrate a reusable baseline security audit for small startups that cannot afford a full penetration test or managed security service. The checklist covers network exposure, transport security, web application hardening, identity and access, and cloud storage.

Overall result. Four findings were identified and rated as if the same setup were an internet-facing production application: 1 Critical, 1 High, 1 Medium and 1 Low. Of 21 checklist items reviewed, 7 failed, 1 passed, 2 were observations, 1 could not be determined and 10 were not applicable or not assessable in this lab. The most serious issue is that default credentials are accepted, followed by the lack of HTTPS and missing secure cookie attributes.

Context. DVWA is intentionally vulnerable, so these results are expected. Their value is in showing the audit method, evidence handling and risk rating, not in judging DVWA itself.

2. Scope and Environment

Target	DVWA (ghcr.io/digininja/dvwa) at http://127.0.0.1:4280, backed by a MariaDB 10 container
Platform	Ubuntu 24.04.1 LTS on WSL2; Docker 29.1.3 with Docker Compose
Tools	Nmap 7.94SVN, curl, Burp Suite Community v2026.8, Docker CLI, ss and lsof
Included	Port and service exposure on 127.0.0.1; HTTP responses, headers and cookies; login behaviour; container port publishing; listening sockets on the host
Excluded	Internet-facing exposure; TLS testing (no HTTPS listener); MFA, password policy and role management (not offered by DVWA); cloud storage; exploitation of DVWA's built-in vulnerabilities
Authorization	Self-owned laboratory; testing performed with the owner's permission
Note	The DVWA security level was set to <i>impossible</i> during testing

3. Methodology

Findings are based on the evidence collected for each checklist item, and each is mapped to CIS Controls v8. Risk = Likelihood x Impact, rated Low, Medium or High and combined into Low, Medium, High or Critical. Ratings assume a production-hypothetical deployment; actual lab exposure is limited to 127.0.0.1.

Tool / method	Purpose
Nmap	Full-port scan of 127.0.0.1, service and version detection, HTTP title, header and method scripts
curl	Response headers, cookies, OPTIONS request and a 404 test on port 4280
Burp Suite	Proxy history and Repeater to inspect the login POST, session cookies, error pages and responses
Docker inspection	docker ps, docker port and docker compose ps to see which container ports are published; docker inspect for container networking
ss and lsof	Listening sockets on the host, including SSH and the containerd listener on 42881
Manual review	Applicability of identity and access checks (MFA, password policy, roles) and cloud storage checks

4. Assessment Results

ID	Finding	Likelihood	Impact	Risk
F-01	HTTP-only application and insecure session transport	Medium	High	High
F-02	Missing security response headers	Medium	Medium	Medium
F-03	Server and PHP version disclosure	Low	Low	Low
F-04	Default credentials accepted (DVWA demonstration)	High	High	Critical

5. Detailed Findings

F-01 - HTTP-only application and insecure session transport

Risk	High (Likelihood: Medium, Impact: High)
CIS v8	3 - Data Protection / 3.10 Encrypt Sensitive Data in Transit
Evidence	Nmap shows 443/tcp closed and 4280/tcp open. curl and Burp show the application served over plain HTTP. The PHPSESSID cookie is set with HttpOnly and SameSite=Strict but without the Secure attribute; the security cookie has neither Secure nor SameSite. See Figures 1 and 2.
Impact	On a real network, an attacker on the traffic path could read credentials and session tokens sent over HTTP, and could hijack sessions because the cookies are not restricted to HTTPS.
Recommendation	Deploy HTTPS with a valid certificate and TLS 1.2 or higher, redirect all HTTP traffic to HTTPS, enable HSTS once HTTPS works, and set the Secure attribute on all cookies (for PHP: session.cookie_secure = On).

```
spandana@LENOVO:~/DVWA$ nmap -p 4280,443 127.0.0.1
Starting Nmap 7.94SVN ( https://nmap.org )
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00039s latency).

PORT      STATE SERVICE
443/tcp    closed https
4280/tcp   open  vrml-multi-use

Nmap done: 1 IP address (1 host up) scanned in 0.05 seconds
```

Figure 1. Nmap scan of ports 4280 and 443: 443/tcp closed, 4280/tcp open (HTTP only).

```
spandana@LENOVO:~/DVWA$ curl -s -D - http://127.0.0.1:4280/login.php -o /dev/null
HTTP/1.1 200 OK
Date:
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.10
Set-Cookie: security=impossible; path=/; HttpOnly
Set-Cookie: PHPSESSID= expires= Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID= expires= Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Vary: Accept-Encoding
Content-Length: 1342
Content-Type: text/html; charset=utf-8
```

Figure 2. curl response headers from /login.php: PHPSESSID and security cookies set without the Secure attribute.

F-02 - Missing security response headers

Risk	Medium (Likelihood: Medium, Impact: Medium)
CIS v8	16 - Application Software Security / 16.7 Use Standard Hardening Configuration Templates for Application Infrastructure
Evidence	A header check with curl, plus Burp Repeater responses, showed no Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy or Permissions-Policy. See Figures 3 and 4.
Impact	The browser gets no instruction to limit framing, MIME sniffing or script sources, which increases exposure to clickjacking and to the impact of injected scripts.
Recommendation	Add the headers in the Apache configuration using mod_headers: a Content-Security-Policy (test in report-only mode first), X-Frame-Options (DENY or SAMEORIGIN), X-Content-Type-Options: nosniff, Referrer-Policy and Permissions-Policy.

```
spandana@LENOVO:~/DVWA$ curl -s -I http://127.0.0.1:4280/login.php | grep -Ei 'Strict-Transport|Content-Security|X-Frame|X-Content-Type|Referrer-Policy|Permissions-Policy'
spandana@LENOVO:~/DVWA$
```

Figure 3. curl header check for HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy: no matching headers returned.

```
spandana@LENOVO:~/DVWA$ curl -s -D - -o /dev/null http://127.0.0.1:4280/login.php | grep -Ei '^([HTTP/]|Server:|X-Powered-By:|Content-Security-Policy:|X-Frame-Options:|X-Content-Type-Options:|Strict-Transport-Security:)'
HTTP/1.1 200 OK
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.10
spandana@LENOVO:~/DVWA$
```

Figure 4. curl response filtered for security headers: only Server and X-Powered-By are present.

F-03 - Server and PHP version disclosure

Risk	Low (Likelihood: Low, Impact: Low)
CIS v8	4 - Secure Configuration / 4.1; 16 - Application Software Security
Evidence	Normal responses carry Server: Apache/2.4.68 (Debian) and X-Powered-By: PHP/8.5.10. A 404 response on port 4280 also names Apache/2.4.68 (Debian) in the header and in the page body. See Figures 5 and 6.
Impact	Version details make it easier for an attacker to look up known weaknesses. Disclosure alone does not prove the software is vulnerable.
Recommendation	Set ServerTokens Prod and ServerSignature Off in Apache, and expose_php = Off in PHP. Keep the software patched regardless.

```
spandana@LENOVO:~/DVWA$ nmap -sV -p 4280 --script http-title,http-methods 127.0.0.1
Starting Nmap 7.94SVN ( https://nmap.org )
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0012s latency).

PORT      STATE SERVICE VERSION
4280/tcp  open  http      Apache httpd 2.4.68 ((Debian))
|_ http-title: Login :: Damn Vulnerable Web Application (DVWA)
|_ Requested resource was login.php
|_ http-server-header: Apache/2.4.68 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-headers:
|_   Date:
|_   Server: Apache/2.4.68 (Debian)
|_   X-Powered-By: PHP/8.5.10
|_   Set-Cookie: security-impossible; path=/; HttpOnly
|_   Set-Cookie: PHPSESSID=; expires=; Max-Age=86400; path=/; domain=localhost; HttpOnly; SameSite=Strict
|_   Expires: Tue, 23 Jun 2009 12:00:00 GMT
|_   Cache-Control: no-cache, must-revalidate
|_   Pragma: no-cache
|_   Set-Cookie: PHPSESSID=; expires=; Max-Age=86400; path=/; domain=localhost; HttpOnly; SameSite=Strict
|_   Connection: close
|_   Content-Type: text/html; charset=utf-8
|_ (Request type: HEAD)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.69 seconds
spandana@LENOVO:~/DVWA$
```

Figure 5. Nmap http-headers and http-methods output showing Server: Apache/2.4.68 (Debian) and X-Powered-By: PHP/8.5.10.

```
spandana@LENOVO:~/DVWA$ curl -s -i -X OPTIONS http://127.0.0.1:4280/login.php | grep -Ei '^(HTTP/|Allow:)'
HTTP/1.1 200 OK
spandana@LENOVO:~/DVWA$ curl -s -i http://127.0.0.1:4280/nonexistent-test-page-12345
HTTP/1.1 404 Not Found
Date:
Server: Apache/2.4.68 (Debian)
Content-Length: 313
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 4280</address>
</body></html>
```

Figure 6. curl request to a nonexistent page on port 4280: the 404 discloses Apache/2.4.68 (Debian) in the header and the page body.

F-04 - Default credentials accepted (DVWA demonstration)

Risk	Critical (Likelihood: High, Impact: High)
CIS v8	4.7 Manage Default Accounts; 5.2 Use Unique Passwords
Evidence	An authorized login using DVWA's documented default credentials succeeded: the POST to /login.php returned 302 to index.php and issued a new session cookie (Burp Proxy history). See Figure 7.
Impact	On an internet-facing system, publicly known default credentials give an attacker direct authenticated access. This is a deliberate DVWA weakness, not a claim about DVWA's quality.
Recommendation	Change or remove all default accounts before deployment, require unique strong passwords, force a password change at first login, and add MFA for administrative accounts.

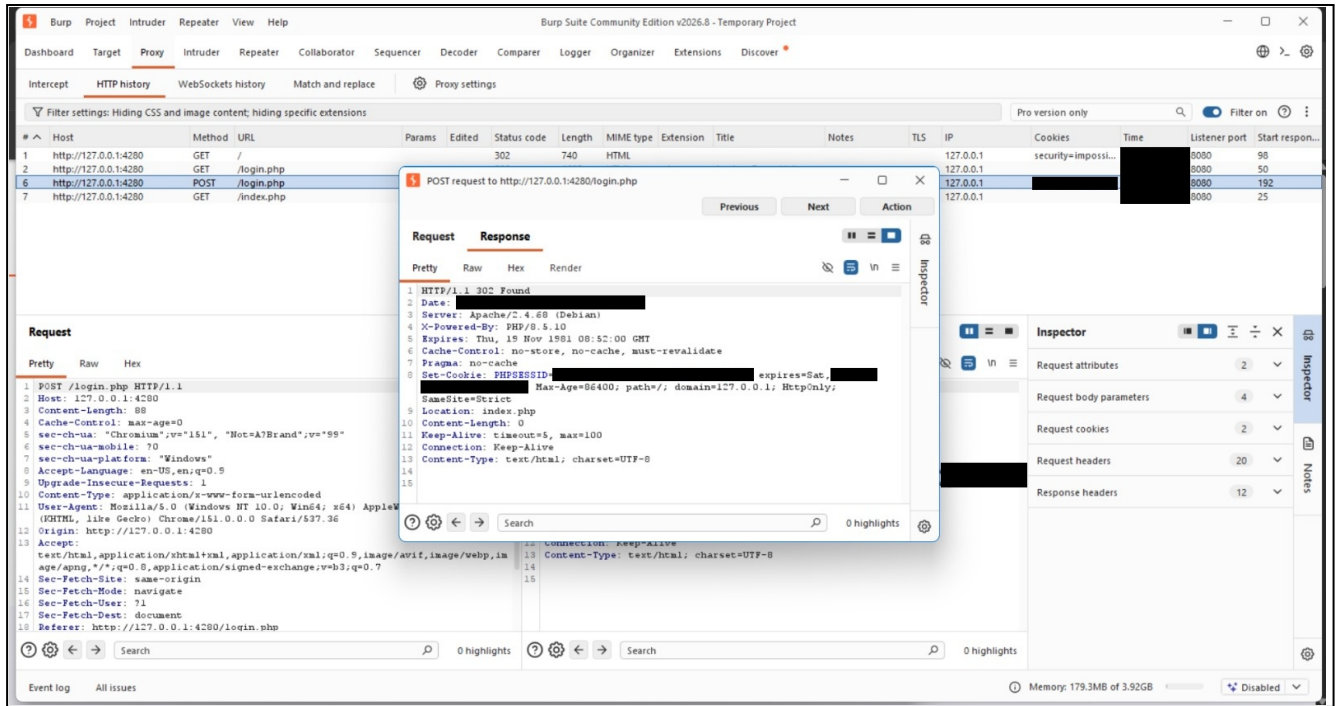


Figure 7. Burp Suite Proxy history: POST /login.php returned 302 to index.php with a new session cookie.

6. Remediation Plan

Priority	Finding	Action	Effort
1	F-04	Replace default credentials, enforce unique strong passwords, add MFA for admins	Low
2	F-01	Deploy HTTPS, redirect HTTP, enable HSTS, set Secure on cookies	Medium
3	F-02	Add CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy	Low to Medium
4	F-03	ServerTokens Prod, ServerSignature Off, expose_php = Off	Low

Also worth doing in a real deployment: confirm SSH is limited by firewall or security group rules and uses key-based login, and keep the database unpublished as it is now.

7. Limitations

- Testing was performed against localhost only, so Internet exposure was not established. SSH listening on 0.0.0.0:22 was recorded as not determined.
- DVWA is intentionally vulnerable, so several results are expected. Ratings are production-hypothetical, not measurements of real business risk.
- TLS versions, ciphers and certificates, MFA, password policy, role management, admin-panel rate limiting and cloud storage could not be assessed because DVWA did not provide them.
- The security level was set to impossible during testing, and the built-in DVWA vulnerabilities were not exploited.
- Results are a point-in-time snapshot from 18 September 2026 and do not establish formal CIS compliance.

8. Conclusion

This assessment showed that the baseline audit method works end to end: it collects evidence with common tools, marks checks that do not apply as N/A instead of forcing a result, rates risk with a consistent matrix and maps findings to CIS Controls v8. The same checklist and reporting structure can be reused for real small-business systems, where the remediation plan above would be the starting point for fixes.

Appendix A - Supporting Evidence

```

spandata@INNOVO:~/JPMW$
spandata@INNOVO:~/JPMW$ nmap -v -x -p 127.0.0.1
Starting Nmap 7.94SVN ( https://nmap.org )
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00010s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
  256 ba:2e:5b:56:9d:8e:63:1d:71:5c:3d:d7:62:ab:06:fe (ECDSA)
  256 00:5c:96:22:06:89:4a:c1:9c:0c:41:82:61:a6:ca:19 (ED25519)
4280/tcp  open  http     Apache httpd 2.4.68 ((Debian))
http-robots.txt: 1 disallowed entry
_/
http-title: Login :: Damn Vulnerable Web Application (DVWA)
Requested resource was login.php
http-server-header: Apache/2.4.68 (Debian)
42881/tcp open  unknown
fingerprint-strings:
FourOhFourRequest:
  HTTP/1.0 404 Not Found
  Date: 
  Content-Length: 19
  Content-Type: text/plain; charset=utf-8
  404: Page Not Found
GenericLines, Help, Kerberos, LDAPSearchReq, LPDString, RTSPRequest, SSLSessionReq, TLSSessionReq, TerminalServerCookie:
HTTP/1.1 400 Bad Request
Content-Type: text/plain; charset=utf-8
Connection: close
Request
GetRequest, HTTPOptions:
HTTP/1.0 404 Not Found
Date: 
Content-Length: 19
Content-Type: text/plain; charset=utf-8
404: Page Not Found
I service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port42881-TCP-V=7.94SVN/X=7X0-9/18XItime=6ACE78E3P=x86_64-pc-linux-gnuX
SF-r(GenericLines,67,"HTTP/1\.\1\x20400\x20Bad\x20Request\r\nContent-Type:\r\nSF:x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20B
SF:ad\x20Request")&r(GetRequest,8F,"HTTP/1\.\0\x20404\x20Not\x20Found\r\nDa
SF:te: \r\nContent-Length:\r\nSF:x2019\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n\r\n404:\x20P
SF:age\x20Not\x20Found")&r(HTTPOptions,8F,"HTTP/1\.\0\x20404\x20Not\x20Foun
SF:d\r\nDate: \r\nContent-L
SF:length:\x2019\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n\r\n40
SF:4:\x20Page\x20Not\x20Found")&r(RTSPRequest,67,"HTTP/1\.\1\x20400\x20Bad\
SF:x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConnecti
SF:on:\x20close\r\n\r\n400\x20Bad\x20Request")&r(Help,67,"HTTP/1\.\1\x20400
SF:\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n

```

Figure 8. Nmap full-port scan (-sV -sC -p-) of 127.0.0.1: open ports 22, 4280 and 42881; 65,532 ports closed.

```
spandana@LENOVO:~/DVWA$ sudo ss -ltnp
[sudo] password for spandana:
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port      Process
LISTEN     0            4096         127.0.0.53:10:53        0.0.0.0:*               users:((("systemd-resolve",pid=173,fd=15))
LISTEN     0            4096         127.0.0.1:42881        0.0.0.0:*               users:((("containerd",pid=264,fd=15))
LISTEN     0            1000        10.255.255.254:53      0.0.0.0:*               users:((("sshd",pid=246,fd=3),("systemd",pid=1,fd=69))
LISTEN     0            4096         0.0.0.0:0:0:0:0:22      0.0.0.0:*               users:((("systemd-resolve",pid=173,fd=17))
LISTEN     0            4096        127.0.0.54:53         0.0.0.0:*               users:((("docker-proxy",pid=743,fd=7))
LISTEN     0            4096        127.0.0.1:4280        0.0.0.0:*               users:((("sshd",pid=246,fd=4),("systemd",pid=1,fd=70))
LISTEN     0            4096         :::22                 :::*                     users:((("sshd",pid=246,fd=4),("systemd",pid=1,fd=70))
```

Figure 9. ss -lntp output: sshd on 0.0.0.0:22 and [::]:22, containerd on 127.0.0.1:42881, docker-proxy on 127.0.0.1:4280.

```
spandana@LENOVO:~/DVWA$ docker ps --format "table {{.Names}} \t {{.Ports}}"
NAMES          PORTS
dvwa-dvwa-1    127.0.0.1:4280->80/tcp
dvwa-db-1      3306/tcp
spandana@LENOVO:~/DVWA$
```

Figure 10. docker ps: DVWA published on 127.0.0.1:4280 only; the database container exposes 3306/tcp without a host mapping.